

Data Privacy & Compliance

Generative AI for Business Leaders & C-Suite | AI Risk Management & Governance

1. The Privacy Paradox of Generative AI

Generative AI creates a fundamental tension: these tools are most powerful when given rich, detailed data to work with, yet privacy regulations exist precisely to limit how personal and sensitive data is shared, processed, and stored. Business leaders must navigate this paradox daily. The marketing team wants to feed customer interaction histories into an AI to generate personalised campaigns. The HR team wants to use AI to screen resumes. The legal team wants AI to review contracts containing client confidential information. Every use case is legitimate. Every one creates privacy exposure if handled carelessly.

The good news is that enterprise AI platforms have been engineered specifically to resolve this tension. The challenge is that most organisations do not yet understand the specific guarantees these platforms provide, how those guarantees map to regulatory requirements, or what internal processes must accompany the technology to achieve genuine compliance.

2. Enterprise AI Data Protection Guarantees — What You Are Actually Buying

When an organisation pays for enterprise AI — typically \$20-60 per user per month — it is not buying better features. It is buying a legally enforceable set of data handling commitments. Understanding exactly what these guarantees entail is essential for any compliance or procurement discussion.

Guarantee	What It Means in Practice	Why It Matters for Compliance
Data isolation	Your organisation's prompts, responses, and uploaded files are stored in a logically or physically separate environment from all other customers	Prevents cross-contamination of data between tenants; addresses concerns about competitors accessing your information on a shared platform
No-training clause	The vendor contractually commits that your inputs and outputs will never be used to train, fine-tune, or improve any AI model — not even the vendor's own models	Eliminates the risk that your proprietary or personal data appears in the model's responses to other users; critical for trade-secret protection and GDPR data minimisation requirements
Encryption in transit and at rest	All data is encrypted using TLS 1.2+ when transmitted and AES-256 when stored; some vendors offer customer-managed encryption keys (BYOK)	Meets encryption requirements under GDPR Article 32, HIPAA, PCI DSS, and most industry-specific security standards
Data residency controls	You can specify the geographic region(s) where your data is processed and stored — often down to specific countries or even data centre locations	Addresses GDPR's Chapter V restrictions on cross-border data transfers, Schrems II ruling implications, and data sovereignty requirements in jurisdictions like China, Russia, and Brazil
Compliance	Enterprise platforms typically hold SOC	Provides auditable evidence that the

certifications	2 Type II, ISO 27001, and industry-specific certifications such as HIPAA, FedRAMP, or PCI DSS	vendor meets recognised security standards — essential for your own audit and regulatory reporting obligations
Data retention and deletion controls	You can set retention periods and request deletion of all stored data; the vendor must comply within contractually specified timeframes	Enables compliance with GDPR's right to erasure (Article 17), CCPA's right to delete, and internal data lifecycle management policies

Key Point: These guarantees are contractual — they live in your enterprise agreement, not in a marketing brochure. If the vendor violates them, you have legal recourse. This is fundamentally different from a consumer terms-of-service page that the vendor can change at any time.

3. GDPR and AI — What the Regulation Actually Requires

The General Data Protection Regulation is the most comprehensive privacy framework affecting AI usage in business. Even non-European organisations must comply if they process data of EU residents. GDPR does not ban AI — but it imposes specific obligations on organisations that use AI to process personal data.

Lawful basis for processing

GDPR Article 6 requires a lawful basis for any processing of personal data. When you use AI on personal data, you must identify which basis applies. The three most relevant for AI usage are:

Lawful Basis	When It Applies to AI	Practical Example
Consent (Article 6(1)(a))	When you have obtained explicit, informed consent from the data subject for AI processing specifically	A customer opts in to AI-powered personalised product recommendations, having been told that an AI system will analyse their purchase history
Contractual necessity (Article 6(1)(b))	When AI processing is necessary to fulfil a contract with the data subject	An insurance company uses AI to process claims faster — the processing is necessary to deliver the service the customer contracted for
Legitimate interest (Article 6(1)(f))	When your organisation has a legitimate business interest that is not overridden by the data subject's rights	A bank uses AI for fraud detection — the bank's interest in preventing fraud is legitimate and does not disproportionately impact customer rights

Transparency and the right to explanation

GDPR Articles 13-14 require that you inform data subjects about how their data is processed. If you use AI, your privacy notice must disclose this. Article 22 adds a specific right: data subjects have the right not to be subject to decisions based solely on automated processing that significantly affects them. This

means AI-only decisions about credit approvals, job applications, insurance eligibility, or service access require either explicit consent or human oversight. In practice, most organisations implement human-in-the-loop review for consequential AI decisions rather than seeking explicit consent for automated decision-making, because the consent requirements under Article 22 are stringent.

Data minimisation and purpose limitation

GDPR's data minimisation principle (Article 5(1)(c)) requires that you process only the personal data necessary for your stated purpose. This has a direct practical implication for AI: do not feed entire customer databases into AI tools. Extract and anonymise only the data elements necessary for the specific task. Purpose limitation (Article 5(1)(b)) means data collected for one purpose cannot be repurposed for AI training or analysis without a separate lawful basis. If you collected email addresses for order confirmations, you cannot feed them into an AI tool for marketing analysis without additional consent or a separate legitimate interest assessment.

4. CCPA, CPRA, and the Expanding US State Privacy Landscape

The California Consumer Privacy Act (CCPA), as amended by the California Privacy Rights Act (CPRA), creates obligations similar to GDPR for California residents' data. As of 2024, over a dozen US states have enacted comprehensive privacy laws, with more pending. While these laws differ in specifics, they share common AI-relevant requirements.

Requirement	GDPR	CCPA/CPRA	Practical Impact on AI
Right to know	Yes (Articles 13-14)	Yes (Section 1798.100)	Must disclose AI processing in privacy notices
Right to delete	Yes (Article 17)	Yes (Section 1798.105)	Must be able to delete data from AI systems on request
Right to opt out of automated decisions	Yes (Article 22)	Yes, for profiling (CPRA Section 1798.185)	Must offer human review alternative for consequential decisions
Data minimisation	Yes (Article 5(1)(c))	Implied through purpose limitation	Do not over-feed data into AI tools
Vendor contracts	Required DPA (Article 28)	Required service provider agreement	Enterprise AI vendors must sign compliant agreements

Real-World Incident — Sephora CCPA Settlement (2022): Sephora agreed to pay \$1.2 million to settle allegations that it failed to disclose the sale of consumer personal information through third-party analytics and advertising technologies, and failed to honour opt-out requests. While not an AI-specific case, it established an important precedent: regulators treat data sharing with technology platforms as data processing subject to privacy law, regardless of whether the platform uses traditional analytics or AI. Organisations that share customer data with AI tools without proper disclosure face similar enforcement risk.

5. Industry-Specific Compliance Requirements

Beyond general privacy laws, specific industries face additional obligations that directly affect AI usage.

Healthcare — HIPAA

The Health Insurance Portability and Accountability Act requires a Business Associate Agreement (BAA) with any AI vendor that will process Protected Health Information (PHI). Not all enterprise AI platforms offer HIPAA-compliant configurations, so procurement must verify this explicitly. Key requirements include: the BAA must specify how PHI is used, stored, and protected within the AI platform; AI-generated outputs containing PHI must be treated as PHI themselves; audit trails must track who accessed patient data through AI and when; and the minimum necessary standard applies — feed only the specific patient data elements needed for the AI task, not entire medical records.

Financial Services — GLBA, SOX, and Sectoral Rules

Financial institutions face overlapping obligations from the Gramm-Leach-Bliley Act (GLBA), Sarbanes-Oxley (SOX), and specific regulators. AI used in credit decisions must comply with the Equal Credit Opportunity Act and Fair Credit Reporting Act, meaning the organisation must be able to explain why a credit application was denied even when AI was involved in the decision. Model risk management guidance from the OCC and Federal Reserve (SR 11-7) applies to AI models used in financial decisions, requiring documented model development, validation, and ongoing monitoring.

Legal Services

Attorney-client privilege and professional conduct rules create unique constraints. Client data processed by AI must remain confidential, which means AI vendors cannot access it for training or improvement. Many bar associations now require lawyers to disclose AI usage to clients. For the most sensitive legal work — litigation strategy, M&A due diligence, regulatory investigations — on-premises or private cloud AI deployments may be the only option that satisfies ethical obligations.

6. The Data Processing Agreement — Your Most Important AI Contract

A Data Processing Agreement is the legal instrument that governs how an AI vendor handles your data. Under GDPR Article 28, a DPA is mandatory whenever you share personal data with a processor. Even outside GDPR, a DPA is best practice for any AI vendor relationship.

Essential DPA Clauses for AI Vendors

Clause	What It Must Cover	Red Flag If Missing
Purpose limitation	Data may only be processed for the services described in the agreement — not for model training, benchmarking, or improvement	Vendor reserves the right to use data for 'product improvement' or 'service enhancement'
Sub-processor controls	Vendor must list all sub-processors and notify you before adding new ones; you have the right to object	Vendor can engage sub-processors without notice or approval
Data breach notification	Vendor must notify you within a specified timeframe (typically 24-72	No notification timeline specified, or timeline exceeds 72 hours

	hours) of discovering a data breach	
Audit rights	You have the right to audit the vendor's data handling practices, either directly or through an independent auditor	No audit rights, or audit rights limited to reviewing compliance certifications only
Data return and deletion	On contract termination, vendor must return all data and certify complete deletion within a specified timeframe	No deletion timeline, or vendor retains the right to keep anonymised data indefinitely
International transfer mechanisms	If data crosses borders, the DPA must specify the legal mechanism (Standard Contractual Clauses, Binding Corporate Rules, or adequacy decision)	No transfer mechanism specified for cross-border data flows

7. Practical Compliance Implementation — The Eight-Point Checklist

The lecture outlined an eight-point compliance checklist. Here, each item is expanded with implementation guidance for organisations at different maturity levels.

#	Checklist Item	Starter (Month 1)	Mature (Month 3+)
1	Use only enterprise AI platforms with compliance certifications	Identify and procure one enterprise AI platform for the highest-priority use case	Maintain an approved vendor register with annual re-certification reviews
2	Update privacy policies to include AI processing	Add a paragraph to your privacy notice disclosing AI use in data processing	Maintain AI-specific privacy impact assessments (PIAs) for each use case
3	Implement data classification for AI use	Create three tiers: data that can go to cloud AI, data restricted to internal AI, data that must not be processed by AI	Automated classification tools tag data at creation; AI tools enforce classification rules at input
4	Establish human review for consequential decisions	Require manager sign-off on AI-influenced hiring, lending, and customer service escalation decisions	Documented decision frameworks with escalation paths and audit trails for every consequential AI decision
5	Train employees on AI privacy rules	30-minute briefing covering data classification and the AI Acceptable Use Policy	Role-specific training modules: legal staff get DPA training, HR gets bias training, engineers get security training
6	Document AI processing activities	Spreadsheet listing each AI tool, what data it processes, and for what purpose	AI register integrated with your Records of Processing Activities (ROPA) under GDPR Article 30
7	Conduct privacy impact assessments	Complete a PIA for your highest-risk AI use case (e.g., customer-facing chatbot or HR screening)	PIA required before any new AI use case goes into production; privacy-by-design review embedded in AI project approval
8	Respond to data subject rights requests	Ensure your existing DSAR process includes AI vendor data in scope	Automated DSAR workflows that trigger deletion requests to AI vendors within SLA timeframes

8. Common Compliance Mistakes — and How to Avoid Them

Based on enforcement actions, audit findings, and industry experience, certain mistakes recur across organisations beginning their AI compliance journey.

Mistake	Why It Happens	How to Avoid It
Treating AI tools as internal systems rather than external data processors	Employees perceive AI as similar to internal software; they do not recognise data leaves the organisation	Frame AI tools as external vendors in all training and policies; require the same due diligence as any third-party data processor
Failing to update privacy notices when deploying AI	AI is adopted incrementally by individual teams, not through a central launch that would trigger a policy review	Include AI disclosure review in your AI project approval checklist — no new AI use case goes live until privacy notices are updated
Over-feeding data into AI tools	Employees paste entire documents or database exports when the AI only needs a summary or specific fields	Train employees on data minimisation techniques: extract and anonymise before prompting; provide templates showing how to structure AI inputs
Assuming enterprise = fully compliant	Procurement signs the enterprise contract and assumes all compliance obligations are met	Enterprise AI handles vendor-side obligations; you still must implement internal controls (classification, training, review, documentation)
Ignoring AI in data subject access requests	DSAR processes were built before AI was deployed and do not include AI vendor data in scope	Audit your DSAR workflow against your AI vendor register; ensure every vendor with personal data exposure is included in DSAR scope

Key Point: Compliance is not achieved by purchasing enterprise AI. Enterprise tools solve the vendor-side equation — data protection, encryption, isolation. But the organisation-side equation — classification, training, review processes, documentation, and DSAR handling — remains your responsibility. Both sides must be in place.

9. Data Privacy Impact Assessments (DPIAs) for AI

GDPR Article 35 requires a Data Protection Impact Assessment for processing that is "likely to result in a high risk to the rights and freedoms of natural persons." AI-based processing of personal data almost always meets this threshold. Even outside GDPR, conducting a DPIA for AI projects is a best practice that demonstrates due diligence and often identifies risks before they become incidents.

When a DPIA Is Required

- Systematic and extensive profiling with significant effects (e.g., AI-driven credit scoring, insurance pricing, or employee performance assessment)
- Large-scale processing of special category data (health, biometric, genetic, racial/ethnic data) by AI

- Systematic monitoring of publicly accessible areas using AI (e.g., AI-powered CCTV analytics)
- Any use of AI for automated decision-making that produces legal or similarly significant effects on individuals

What a DPIA Should Contain

A practical DPIA for an AI project covers: a description of the AI processing (what data, what model, what decisions it informs); the necessity and proportionality assessment (why AI is needed and whether less intrusive alternatives were considered); the risks to data subjects (bias, inaccuracy, lack of transparency, data breach); and the mitigating measures (enterprise platform guarantees, human review, data minimisation, access controls, monitoring). The DPIA should be reviewed and updated whenever the AI use case changes significantly — a new data source, a different model, or an expanded scope of automated decisions.

10. Key Terms Glossary

Term	Definition
GDPR	General Data Protection Regulation — the EU's comprehensive data privacy law, effective since May 2018, governing the processing of personal data of EU residents
CCPA/CPRA	California Consumer Privacy Act, as amended by the California Privacy Rights Act — grants California residents rights over their personal data including rights to know, delete, and opt out
Data Processing Agreement (DPA)	A legally binding contract between a data controller (your organisation) and a data processor (the AI vendor) specifying how personal data will be handled
Business Associate Agreement (BAA)	A HIPAA-required contract between a covered entity and any vendor that will access, store, or process Protected Health Information
Data Residency	The geographic location where data is stored and processed — critical for compliance with GDPR's cross-border transfer rules and national data sovereignty laws
No-Training Clause	A contractual commitment that the AI vendor will not use your data to train, fine-tune, or improve any AI model
Privacy Impact Assessment (PIA/DPIA)	A systematic assessment of a data processing activity's impact on individuals' privacy, identifying risks and mitigating measures; required under GDPR Article 35 for high-risk AI processing
Data Subject Access Request (DSAR)	A formal request from an individual to exercise their data rights (access, deletion, correction, portability) under GDPR, CCPA, or similar privacy laws
Standard Contractual Clauses (SCCs)	EU-approved contractual templates that provide legal safeguards for transferring personal data from the EU to countries without an adequacy decision
Records of Processing Activities (ROPA)	A documented register of all personal data processing activities conducted by an organisation, required under GDPR Article 30
Data Minimisation	The principle of collecting and processing only the personal data that is strictly necessary for the specified purpose — a core GDPR requirement

SOC 2 Type II	An auditing standard that evaluates a service provider's information security controls over time, verifying they operate effectively over a minimum six-month period
---------------	--

11. Quick Revision Checklist

- Enterprise AI platforms provide six contractual guarantees: data isolation, no-training clause, encryption, data residency, compliance certifications, and retention/deletion controls
- GDPR requires a lawful basis (consent, contract, or legitimate interest) for any AI processing of personal data
- Transparency obligations mean you must disclose AI processing in privacy notices and offer human review for consequential automated decisions
- Data minimisation applies to AI: extract and anonymise only the data elements needed for the specific task — do not paste entire databases into AI tools
- CCPA/CPRA grants California residents similar rights to GDPR; 12+ US states now have comprehensive privacy laws
- Industry-specific rules layer on top: HIPAA requires BAAs for healthcare AI, financial regulations require explainable AI for credit decisions, legal ethics rules require confidentiality protections
- The DPA is your most important AI vendor contract — verify purpose limitation, sub-processor controls, breach notification, audit rights, and deletion clauses
- Enterprise AI solves vendor-side compliance; you must still implement internal controls: data classification, training, human review, documentation, and DSAR handling
- Conduct a DPIA before deploying AI on personal data — it identifies risks early and demonstrates due diligence
- The eight-point compliance checklist covers 90% of privacy concerns: enterprise tools, privacy notices, data classification, human review, training, documentation, PIAs, and DSAR processes

20 Exam-Based MCQs — Data Privacy & Compliance for AI

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* A European retail company uses an enterprise AI platform to generate personalised product recommendations based on customers' purchase histories. The company's privacy notice was last updated in 2019 and does not mention AI processing. A GDPR-savvy customer submits a data subject access request asking how their data is processed. What compliance gap does this situation reveal?

- A) The company should not be using AI for product recommendations under any circumstances
- B) The privacy notice fails to disclose AI processing as required by GDPR Articles 13-14, and the company may lack a documented lawful basis for this specific processing activity
- C) Enterprise AI platforms are exempt from GDPR disclosure requirements
- D) Data subject access requests do not apply to AI-processed data

Answer: B **Explanation:** B is correct because GDPR requires transparency about how personal data is processed, including AI processing. The 2019 privacy notice predates the AI deployment and does not inform data subjects about it. Additionally, the company must verify it has a valid lawful basis (likely legitimate interest for product recommendations) with a documented assessment. A is wrong because AI-powered recommendations are a legitimate use case with proper compliance measures. C is wrong because no AI platform is exempt from GDPR — the regulation applies to the data controller (the company), not the tool. D is wrong because DSARs cover all processing of personal data, including AI-processed data.

Q2. What is the PRIMARY difference between a consumer AI tool's terms of service and an enterprise AI platform's Data Processing Agreement?

- A) Consumer terms are longer and more detailed than enterprise agreements
- B) Enterprise DPAs are legally enforceable contracts with specific data protection commitments, audit rights, and breach notification requirements, while consumer ToS can be changed unilaterally by the vendor
- C) Consumer tools provide better data encryption than enterprise platforms
- D) Enterprise agreements only apply to companies with more than 1,000 employees

Answer: B **Explanation:** B is correct because the enterprise DPA is a negotiated legal agreement with specific, enforceable commitments. If the vendor violates the DPA, the customer has legal recourse. Consumer ToS are unilateral — the vendor can modify them at any time, and the user's only option is to stop using the service. A is wrong because length does not correlate with protection; consumer ToS are often longer but offer fewer protections. C is wrong because enterprise platforms typically offer stronger encryption, including customer-managed keys. D is wrong because enterprise agreements are available to organisations of any size.

Q3. Scenario: A hospital wants to use an AI tool to help radiologists flag potential tumours in medical imaging scans. The hospital has identified two vendors: Vendor A offers an enterprise platform with SOC 2 Type II certification but no HIPAA BAA, and Vendor B offers a platform with both SOC 2 Type II and a signed HIPAA BAA. Which vendor should the hospital select for this use case?

- A) Vendor A, because SOC 2 Type II is the only certification that matters
- B) Vendor B, because a BAA is legally required for any vendor processing Protected Health Information under HIPAA
- C) Either vendor, because AI processing of medical images is exempt from HIPAA
- D) Neither vendor, because AI cannot be used for medical imaging analysis

Answer: B **Explanation:** B is correct because HIPAA requires a BAA with any business associate that creates, receives, maintains, or transmits PHI on behalf of a covered entity. Medical images are PHI. Without a BAA, the hospital violates HIPAA regardless of the vendor's other certifications. A is wrong because SOC 2 alone does not satisfy HIPAA requirements; a BAA is a separate legal obligation. C is wrong because no AI processing of PHI is exempt from HIPAA. D is wrong because AI-assisted medical imaging is an established and growing use case — the regulatory question is about compliance, not permissibility.

Q4. Under GDPR, which lawful basis would MOST likely apply to a bank using AI for real-time fraud detection on customer transactions?

- A) Consent — the bank must ask each customer to opt in to fraud detection
- B) Legitimate interest — the bank has a legitimate interest in preventing fraud, which does not disproportionately impact customer rights
- C) Legal obligation — fraud detection is required by specific EU legislation for all banks
- D) Vital interests — fraud prevention protects customers' physical safety

Answer: B **Explanation:** B is correct because fraud detection is a textbook legitimate interest under GDPR Article 6(1)(f). The bank's interest in preventing fraud is substantial, the processing is proportionate, and it directly benefits customers as well. A is wrong because making fraud detection consent-dependent would allow customers to opt out, making the system ineffective; regulators and courts have consistently accepted legitimate interest for fraud prevention. C is wrong because while financial regulations encourage fraud prevention, they do not specifically mandate AI-based fraud detection under EU law in a way that triggers Article 6(1)(c). D is wrong because vital interests relate to life-threatening situations, not financial fraud.

Q5. *Scenario:* A multinational insurance company based in Germany uses an enterprise AI platform hosted in the United States to process claims from European customers. The company's DPO raises concerns about cross-border data transfers. What legal mechanism must be in place for this data transfer to comply with GDPR?

- A) No mechanism is needed because the data is encrypted during transfer
- B) Standard Contractual Clauses (SCCs) or another approved transfer mechanism between the company and the US-based AI vendor, plus a Transfer Impact Assessment
- C) The company must obtain individual consent from every customer for the US transfer
- D) US-based platforms are automatically approved for EU data transfers under the Privacy Shield

Answer: B **Explanation:** B is correct because GDPR Chapter V restricts personal data transfers to countries without an EU adequacy decision. Following the Schrems II ruling (2020), Standard Contractual Clauses became the primary mechanism for EU-US transfers, supplemented by Transfer Impact Assessments to evaluate whether the destination country's laws provide adequate protection. A is wrong because encryption addresses security, not the legal basis for cross-border transfer — GDPR requires both. C is wrong because while consent is theoretically a derogation, it is impractical for routine processing and regulators discourage relying on it for systematic transfers. D is wrong because the EU-US Privacy Shield was invalidated by the Schrems II ruling in 2020 (though the EU-US Data Privacy Framework replaced it in 2023 for certified companies — the question tests whether students know Privacy Shield was invalidated).

Q6. What does the GDPR principle of 'data minimisation' require when using AI tools?

- A) Use the smallest AI model available for every task
- B) Process only the personal data elements necessary for the specific AI task — do not feed entire databases or documents when a subset or anonymised version would suffice
- C) Limit AI usage to a maximum of 100 queries per day per employee

D) Delete all AI-generated outputs within 24 hours of creation

Answer: B **Explanation:** B is correct because data minimisation (Article 5(1)(c)) requires adequacy, relevance, and limitation to what is necessary. If an AI task needs customer names and purchase categories, you should not paste full customer records including addresses, payment details, and account numbers. A is wrong because data minimisation refers to the data processed, not the model size. C is wrong because there is no numerical limit in GDPR — the principle is about data scope, not query volume. D is wrong because deletion timelines are governed by retention policies, not a blanket 24-hour rule.

Q7. Scenario: An HR department uses an enterprise AI tool to screen resumes for a senior management position. The AI shortlists 10 candidates from 200 applications. One rejected applicant invokes their GDPR Article 22 right not to be subject to a decision based solely on automated processing. What is the organisation's obligation in response to this request?

- A) Ignore the request because AI-assisted resume screening is exempt from Article 22
- B) Ensure a qualified human reviews the applicant's candidacy — the AI recommendation alone is not sufficient for a decision that significantly affects the individual's employment prospects
- C) Provide the applicant with the AI model's source code
- D) Delete the applicant's resume from all systems immediately

Answer: B **Explanation:** B is correct because Article 22 gives data subjects the right not to be subject to decisions based solely on automated processing that produce legal or similarly significant effects. Hiring decisions clearly meet this threshold. The organisation must either ensure meaningful human involvement in the decision or obtain explicit consent for automated processing. A is wrong because resume screening that determines whether someone progresses in a hiring process is exactly the type of consequential automated decision that Article 22 covers. C is wrong because the right to explanation does not extend to source code — the organisation must explain the logic, significance, and envisaged consequences of the processing. D is wrong because the right invoked is Article 22 (automated decision-making), not Article 17 (right to erasure).

Q8. What is the Sephora CCPA settlement's relevance to organisations using AI?

- A) It established that AI is illegal for retail companies in California
- B) It demonstrated that regulators treat data sharing with technology platforms as regulated data processing, setting a precedent that applies equally to AI tools
- C) It required all retailers to obtain a special AI licence from the California Attorney General
- D) It was unrelated to data privacy and concerned product safety instead

Answer: B **Explanation:** B is correct because Sephora's \$1.2 million settlement established that sharing consumer data with third-party technology platforms (analytics and advertising tools) constitutes a 'sale' of personal information under CCPA. This precedent applies directly to organisations sharing customer data with AI platforms — if you share personal data with an AI vendor, it may be classified as a sale or disclosure under CCPA, requiring appropriate disclosures and opt-out mechanisms. A is wrong because the case did not ban AI or any technology. C is wrong because no such licence requirement was created. D is wrong because the case was specifically about consumer data privacy under CCPA.

Q9. Scenario: A law firm is evaluating AI tools for contract review. The managing partner insists that any AI tool must guarantee that client data is never accessible to the AI vendor's employees, even for support or troubleshooting purposes. The IT director explains that most enterprise AI vendors do allow limited employee access for technical support, subject to strict controls. What is the BEST approach to resolving this concern?

- A) Accept any enterprise AI vendor because all enterprise platforms prevent vendor employee access
- B) Negotiate contract terms that restrict vendor employee access to the minimum necessary, require audit logging of any access, and consider on-premises or private cloud deployment for the most sensitive client matters
- C) Abandon the AI project entirely because no vendor can meet zero-access requirements
- D) Use a consumer AI tool instead, since consumer tools do not have support staff

Answer: B Explanation: B is correct because a layered approach addresses the concern pragmatically. Most enterprise vendors allow limited, logged, and controlled access for support; the firm can negotiate strict contractual limits on this access. For the most sensitive matters (M&A, litigation, regulatory investigations), on-premises or private cloud AI eliminates external access entirely. A is wrong because enterprise platforms vary in their access controls; assumptions without verification are dangerous in a legal context. C is wrong because the concern is manageable through contract negotiation and deployment architecture. D is wrong because consumer tools offer less data protection, not more — the lack of visible support staff does not mean no one at the vendor can access data.

Q10. Which of the following is NOT typically included in an enterprise AI platform's compliance certifications?

- A) SOC 2 Type II
- B) ISO 27001
- C) A guarantee that the AI's outputs are always factually accurate
- D) HIPAA compliance capability (with BAA)

Answer: C Explanation: C is correct because compliance certifications cover security controls, data handling, and operational practices — they do not and cannot guarantee the factual accuracy of AI outputs. AI models can hallucinate, generate incorrect information, or produce biased results regardless of the platform's security certifications. A, B, and D are wrong because SOC 2 Type II, ISO 27001, and HIPAA compliance are standard certifications offered by major enterprise AI platforms.

Q11. Scenario: A marketing team at a consumer goods company wants to use AI to analyse customer reviews from their website and generate insights about product sentiment. The reviews contain customer names and sometimes references to health conditions related to the products. The team plans to paste batches of 500 reviews directly into the enterprise AI platform. What data minimisation step should be taken BEFORE the reviews are submitted to the AI?

- A) No steps needed — enterprise AI platforms automatically anonymise data

- B) Remove or pseudonymise customer names and redact health-related information before submitting reviews, since sentiment analysis does not require personal identifiers or health data
- C) Reduce the batch size from 500 to 50 reviews
- D) Translate all reviews into a different language first

Answer: B **Explanation:** B is correct because data minimisation requires removing personal data elements that are unnecessary for the processing purpose. Sentiment analysis needs the review text, not the customer's identity or health information. Removing names and health references before submission reduces privacy risk without affecting the quality of sentiment insights. A is wrong because enterprise AI platforms do not automatically anonymise input data — that is the data controller's responsibility. C is wrong because reducing batch size does not address the data minimisation issue; each review still contains unnecessary personal data. D is wrong because translation does not remove personal data from the text.

Q12. Under GDPR Article 35, when is a Data Protection Impact Assessment (DPIA) required for AI processing?

- A) Only when the AI processes more than 10 million records
- B) Whenever AI processing is likely to result in a high risk to the rights and freedoms of individuals — including profiling, large-scale processing of sensitive data, and automated decision-making with significant effects
- C) Only for AI tools that cost more than EUR 100,000 per year
- D) DPIAs are optional under GDPR and are only required by company policy

Answer: B **Explanation:** B is correct because Article 35 triggers a DPIA based on risk to individuals, not data volume or cost thresholds. Systematic profiling, large-scale special category data processing, and automated decisions with legal or similarly significant effects all meet the high-risk threshold. A is wrong because the trigger is risk level, not record count. C is wrong because cost is irrelevant to the DPIA requirement. D is wrong because DPIAs are mandatory under GDPR when the high-risk criteria are met — they are a legal requirement, not an optional best practice.

Q13. *Scenario:* An e-commerce company receives a GDPR right-to-erasure request from a customer. The data protection team deletes the customer's data from the CRM, email marketing platform, and customer database. However, the team does not request deletion from the enterprise AI platform that processed the customer's purchase history for recommendation personalisation. Is the customer's erasure request fully satisfied?

- A) Yes — AI platforms are exempt from erasure requests
- B) No — the erasure request must extend to all processors that hold the customer's personal data, including the AI vendor, and the company must confirm deletion was completed
- C) Yes — once the source data is deleted, the AI platform's copy becomes anonymous automatically
- D) No, but only if the customer specifically mentions the AI platform in their request

Answer: B **Explanation:** B is correct because GDPR's right to erasure applies to all processing of the data subject's personal data. The data controller (the company) must ensure all processors, including AI vendors, delete the data. The DPA should include provisions for deletion requests and confirmation timelines. A is

wrong because no processor is exempt from erasure obligations. C is wrong because data in the AI platform does not automatically become anonymous when the source is deleted — it remains personal data until explicitly deleted. D is wrong because the customer is not required to identify every system; the controller is responsible for identifying all locations where the data is processed.

Q14. What does 'data residency controls' mean in the context of enterprise AI platforms?

- A) The ability to control which employees can access the AI platform
- B) The ability to specify the geographic region where your data is processed and stored, ensuring compliance with cross-border transfer restrictions
- C) The ability to set data retention periods for AI outputs
- D) The ability to encrypt data before sending it to the AI platform

Answer: B **Explanation:** B is correct because data residency is specifically about geographic location of data processing and storage. This is critical for GDPR compliance (Chapter V restrictions on international transfers), data sovereignty laws in countries like China, Russia, and India, and contractual commitments to clients about where their data is processed. A is wrong because it describes access controls, not data residency. C is wrong because it describes data retention, a related but distinct concept. D is wrong because it describes encryption, which is a security control, not a geographic control.

Q15. *Scenario:* A financial advisory firm uses AI to generate draft investment analyses for clients. A compliance audit reveals that the AI-generated analyses are sent directly to clients without any human review. The firm's compliance officer flags this as a dual violation. Which two compliance concerns does this practice violate?

- A) Data minimisation and data residency
- B) Human oversight requirements for consequential financial advice AND regulatory requirements that financial advice must be reviewed by a qualified professional before distribution
- C) Encryption standards and vendor sub-processor controls
- D) Training requirements and audit logging

Answer: B **Explanation:** B is correct because financial advice that affects client investment decisions is a consequential automated decision requiring human review, and financial regulatory frameworks (MiFID II in the EU, SEC/FINRA rules in the US) require qualified professional review of investment advice before it reaches clients. The dual violation is both a governance failure and a regulatory compliance failure. A is wrong because data minimisation and residency are not the primary concerns here. C is wrong because encryption and sub-processors relate to data handling, not content review. D is wrong because while training gaps may have contributed, the immediate violations are about human review and regulatory compliance.

Q16. According to the lecture, what percentage of privacy and compliance concerns for most organisations is covered by the eight-point compliance checklist?

- A) 50%
- B) 70%

- C) 90%
- D) 100%

Answer: C **Explanation:** C is correct — the lecture states that the eight-item checklist covers 90% of privacy and compliance concerns for most organisations, with the remaining 10% requiring industry-specific or jurisdiction-specific expert guidance. A and B underestimate the coverage. D is wrong because no single checklist can cover every regulatory nuance across all industries and jurisdictions.

Q17. Scenario: A global consulting firm is negotiating a DPA with an enterprise AI vendor. During the review, the firm's legal team notices that the vendor's sub-processor clause states: 'Vendor may engage additional sub-processors at its discretion without prior notice to the customer.' Why should the firm push back on this clause?

- A) Sub-processors are always prohibited under GDPR
- B) Without prior notification of new sub-processors, the firm cannot assess whether additional sub-processors meet its data protection standards or whether the firm needs to update its own ROPA and privacy notices
- C) Sub-processor clauses are optional in DPAs and can be safely removed
- D) The firm should accept this clause because the vendor is responsible for sub-processor compliance

Answer: B **Explanation:** B is correct because GDPR Article 28(2) requires the processor to obtain the controller's prior authorisation before engaging sub-processors. Without notification, the firm cannot verify that new sub-processors have adequate data protection measures, cannot update its records of processing activities, and may unknowingly violate data residency commitments if a new sub-processor is in a different jurisdiction. A is wrong because sub-processors are permitted under GDPR, but their engagement is subject to the controller's authorisation. C is wrong because sub-processor controls are a critical DPA element, not optional. D is wrong because while the processor has direct obligations to sub-processors, the controller retains ultimate accountability for data protection and must be able to verify sub-processor adequacy.

Q18. What is the key difference between purpose limitation and data minimisation under GDPR as they apply to AI?

- A) There is no difference — they are interchangeable terms
- B) Purpose limitation restricts WHAT you can use data FOR (data collected for billing cannot be repurposed for AI marketing without separate justification), while data minimisation restricts HOW MUCH data you use (only the data elements necessary for the specific purpose)
- C) Purpose limitation applies only to healthcare data, while data minimisation applies to all data
- D) Data minimisation is a CCPA concept, not a GDPR concept

Answer: B **Explanation:** B is correct because these are complementary but distinct principles. Purpose limitation (Article 5(1)(b)) means you cannot repurpose personal data for AI uses that are incompatible with the original collection purpose without a new lawful basis. Data minimisation (Article 5(1)(c)) means that even when the purpose is lawful, you should only process the minimum data necessary for that purpose. Together, they require organisations to ask both 'should we use this data for AI?' and 'how little of

this data do we need?' A is wrong because the concepts are distinct. C is wrong because both principles apply across all industries and data types. D is wrong because data minimisation is a core GDPR principle, and CCPA has similar requirements.

Q19. Scenario: A real estate company deploys an AI chatbot on its website to answer prospective buyers' questions. The chatbot collects visitors' names, email addresses, budget ranges, and neighbourhood preferences. The company's privacy notice mentions the chatbot but describes it as 'an automated messaging feature' without mentioning AI or explaining how collected data is processed. What specific compliance improvement is needed?

- A) Remove the chatbot because real estate companies cannot use AI under GDPR
- B) Update the privacy notice to specifically disclose that an AI system processes visitor data, explain what data is collected and for what purpose, identify the lawful basis, and inform visitors of their rights regarding automated processing
- C) Move the chatbot behind a login wall so only registered users can access it
- D) Add a disclaimer on the chatbot saying 'this is not legal advice'

Answer: B **Explanation:** B is correct because GDPR transparency requirements (Articles 13-14) mandate clear, specific disclosure of data processing activities. Describing an AI system as an 'automated messaging feature' obscures the nature of the processing. The notice must identify the AI system, the data collected, the purpose, the lawful basis, the retention period, and the data subject's rights. A is wrong because real estate companies can absolutely use AI with proper compliance. C is wrong because restricting access does not resolve the transparency gap — registered users also need proper disclosure. D is wrong because a generic legal disclaimer does not satisfy GDPR's specific transparency requirements.

Q20. An organisation has completed all eight items on the compliance checklist. What should it do NEXT to maintain ongoing compliance?

- A) Nothing — the checklist is a one-time exercise
- B) Conduct regular reviews: update privacy notices when AI use cases change, retrain employees annually, audit vendor compliance, refresh DPIAs when processing changes, and monitor regulatory developments for new requirements
- C) Hire a full-time AI compliance officer and delegate all responsibility
- D) Cease all AI usage until the next regulatory guidance is published

Answer: B **Explanation:** B is correct because compliance is not a one-time project — it is an ongoing programme. AI use cases evolve, new vendors are onboarded, regulations are updated, and employees join and leave. Regular reviews ensure the compliance framework remains current. A is wrong because the regulatory landscape, technology, and business use of AI all change continuously. C is wrong because while a dedicated compliance role may be valuable, compliance is an organisational responsibility that cannot be delegated entirely to one person. D is wrong because ceasing AI usage is unnecessary when a compliance programme is in place; the purpose of compliance is to enable responsible use, not to prevent use.